

Nama : Fajar Geran Arifin

NPM : 237006079

Kelas : C

Mata Kuliah : Blockchain

Dosen Pengampu : Dr. Ir. Nur Widiyasono, M.Kom.

Bagian A Ujian Berbasis Kasus

Bobot 60 poin. Bacalah konteks setiap kasus, kemudian jawab seluruh pertanyaan secara argumentatif.

Kasus 1 Sistem Ketertelusuran Produk Pangan

Sebuah konsorsium terdiri atas koperasi petani, pabrik pengolahan, perusahaan logistik, laboratorium mutu, dan jaringan ritel. Saat ini data lot produksi tersimpan pada basis data masing-masing organisasi. Ketika terjadi penarikan produk, pencocokan nomor lot memerlukan dua hingga tiga hari. Konsorsium ingin memperoleh jejak audit bersama, tetapi harga pemasok dan identitas petani tertentu tidak boleh terlihat oleh semua pihak. Volume transaksi diperkirakan 25 transaksi per detik dan peserta jaringan telah diketahui identitasnya.

1.1 Identifikasi tiga kebutuhan bisnis dan dua kendala teknis yang menentukan desain sistem. [4 poin | CPMK 1 dan CPMK 2 | C4]

Jawaban:

Berdasarkan konteks konsorsium rantai pasok pangan, berikut adalah identifikasi tiga kebutuhan bisnis dan dua kendala teknis penentu desain sistem:

A. Tiga Kebutuhan Bisnis:

1. Jejak Audit Bersama yang Abadi (Immutable Audit Trail): Konsorsium membutuhkan satu sumber kebenaran data tunggal yang transparan dan tahan manipulasi untuk mendokumentasikan silsilah bahan baku dari perkebunan hingga gerai ritel, mengeliminasi sengketa data dan ketergantungan rekonsiliasi manual antar-organisasi.

2. Akselerasi Penarikan Produk (Rapid Product Recall): Memangkas durasi pencocokan nomor lot terdampak dari dua sampai tiga hari menjadi hitungan menit atau jam guna memitigasi risiko keamanan konsumen dan menekan kerugian finansial akibat penarikan massal yang salah sasaran.

3. Perlindungan Kerahasiaan Komersial Selektif (Selective Confidentiality): Melindungi data bisnis rahasia, seperti harga pembelian bahan baku antar-pemasok dan identitas privat petani tertentu, agar tidak terlihat oleh pihak non-rekanan, namun integritas dan keabsahan transaksinya tetap dapat diverifikasi.

B. Dua Kendala Teknis:

1. Throughput Transaksi dan Finalitas Deterministik: Sistem harus mampu memproses throughput operasional sekitar 25 transaksi per detik dengan latensi rendah dan finalitas deterministik tanpa risiko percabangan *ledger*, guna menjamin kelancaran serah terima operasional logistik.

2. Penyimpanan Hibrida dan Integrasi Sistem Warisan: Berkas biner berukuran besar (foto komoditas, sertifikat inspeksi, berkas laporan laboratorium) tidak layak disimpan langsung di *on-chain ledger* karena beban komputasi *node*, sehingga memerlukan integrasi penyimpanan *off-chain* terenkripsi serta penyelarasan dengan basis data internal ERP eksisting.

1.2 Pilih jenis blockchain dan mekanisme konsensus yang paling sesuai. Bandingkan pilihan Anda dengan sekurang-kurangnya satu alternatif. [5 poin | CPMK 2 | C5]

Jawaban:

A. Pemilihan Jenis Blockchain dan Mekanisme Konsensus:

Jenis blockchain yang paling tepat adalah *permissioned consortium blockchain* berbasis Hyperledger Fabric, dengan mekanisme konsensus *ordering service* berbasis *Byzantine Fault Tolerant*, yaitu SmartBFT.

B. Argumentasi dan Analisis Trade-off:

1. Kesesuaian Tata Kelola: Seluruh anggota konsorsium telah diketahui identitas hukumnya. Hyperledger Fabric mengautentikasi setiap *node* melalui *Certificate Authority* (CA) dan *Membership Service Provider* (MSP), meniadakan mekanisme penambangan anonim publik yang boros energi dan biaya transaksi *gas fee* fluktuatif.

2. Skalabilitas Performa: Beban 25 transaksi per detik tergolong sangat wajar dan berada jauh di bawah kapasitas puncak Hyperledger Fabric yang mampu melayani ratusan hingga ribuan transaksi per detik dengan finalitas deterministik sub-detik.

3. Analisis Trade-off Konsensus: Konsensus Raft (*Crash Fault Tolerant*) memang berkinerja tinggi, namun hanya tahan terhadap *node* yang padam, bukan *node* yang bertindak curang atau mengirimkan data bertentangan. Karena anggota konsorsium adalah entitas bisnis independen dengan potensi persaingan komersial, SmartBFT jauh lebih unggul karena mampu mentoleransi hingga f *node* jahat dari total $3f + 1$ *node* pemesanan.

C. Evaluasi Komparatif terhadap Alternatif:

Perbandingan komparatif antara Hyperledger Fabric yang diusulkan terhadap alternatif jaringan blockchain lainnya dirangkum secara sistematis pada Tabel 1.

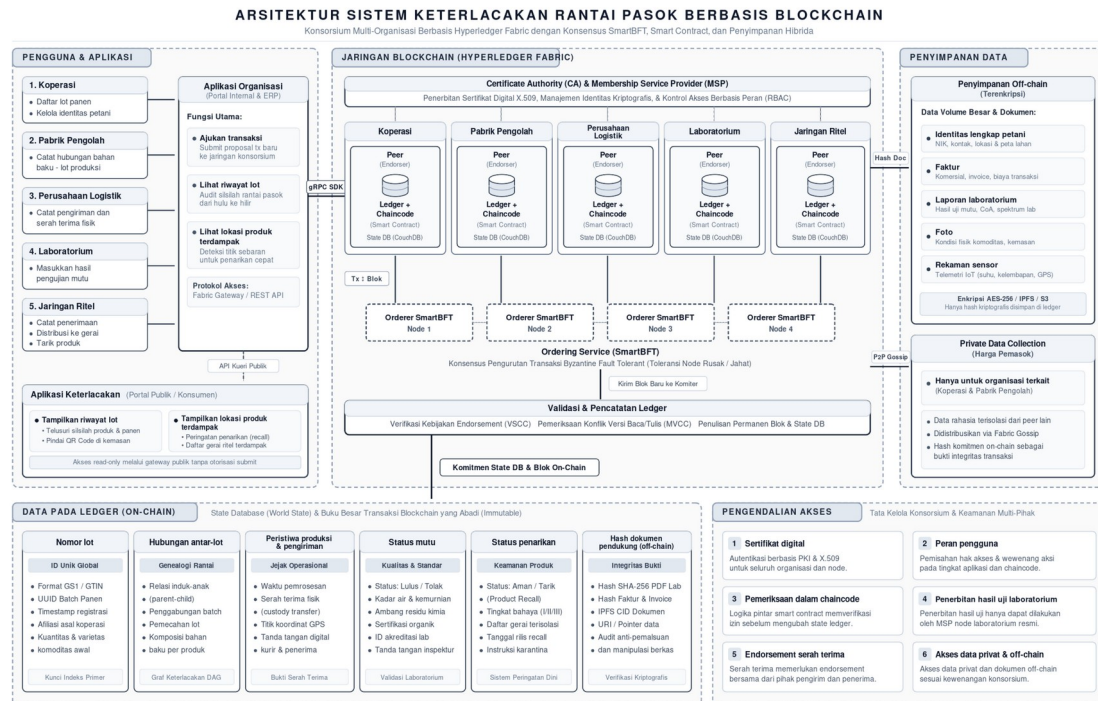
Tabel 1. Perbandingan platform blockchain dan mekanisme konsensus

Kriteria Evaluasi	Hyperledger Fabric (SmartBFT) [Pilihan yang Diusulkan]	Ethereum Publik (PoS) [Alternatif 1]	Hyperledger Besu (IBFT 2.0) [Alternatif 2]
Akses Jaringan	<i>Permissioned consortium</i> ; akses terbatas bagi anggota terdaftar.	Permissionless publik; siapa pun dapat membaca dan menulis data.	<i>Permissioned private</i> ; akses <i>node</i> dibatasi oleh <i>smart contract</i> .
Mekanisme Konsensus	SmartBFT (<i>Byzantine Fault Tolerant</i>) pada <i>ordering service</i> .	<i>Proof-of-Stake</i> (PoS) berbasis validator publik global.	IBFT 2.0 / QBFT berbasis voting antar-validator terpercaya.
Privasi Data Bisnis	Tinggi; isolasi bilateral via <i>Private Data Collections</i> dan <i>channel</i> .	Rendah; data transaksi dan <i>payload</i> terbuka transparan <i>on-chain</i> .	Sedang; privasi grup via Tessera / Orion private transactions.
Finalitas Transaksi	Instan dan deterministik (sub-detik tanpa risiko fork).	Probabilistik; finalitas blok membutuhkan waktu 12 sampai 15 menit.	Deterministik instan dalam hitungan detik per blok.
Biaya Transaksi	Nol biaya <i>gas fee</i> per transaksi (biaya operasional infrastruktur).	Fluktuatif dan tinggi mengikuti beban pasar <i>gas fee</i> .	Nol <i>gas fee</i> internal (dapat disetel biaya gas nol).
Tata Kelola Jaringan	Ketat via <i>Certificate Authority</i> (CA) dan MSP berbasis PKI.	Terdesentralisasi publik tanpa identitas hukum terikat.	Konsorsium berbasis daftar izin alamat akun validator.
Kecocokan Beban 25 TPS	Sangat optimal; throughput kapasitas Fabric mencapai >1000 TPS.	Kurang cocok; rentan kemacetan antrean transaksi dan lonjakan biaya.	Cukup optimal; mampu menangani ratusan TPS stabil.

1.3 Gambarkan arsitektur logis yang menunjukkan aktor, node, data on-chain, data off-chain, serta mekanisme kontrol akses. [4 poin | CPMK 2 | C6]

Jawaban:

Arsitektur logis sistem ketertelusuran produk pangan terintegrasi yang diusulkan ditampilkan pada Gambar 1.



Gambar 1. Arsitektur logis sistem ketertelusuran pangan

Penjelasan Gambar: Arsitektur pada Gambar 1 mengintegrasikan lima aktor konsorsium (Koperasi, Pabrik Pengolah, Perusahaan Logistik, Laboratorium, dan Jaringan Ritel) yang berinteraksi melalui Aplikasi Organisasi untuk submit transaksi dan monitoring lot, serta Aplikasi Keterlacakan untuk akses publik konsumen via pemindaian kode QR. Pada lapisan jaringan Hyperledger Fabric, setiap organisasi mengoperasikan *peer node* yang menyimpan *world state* (CouchDB) dan mengeksekusi logika bisnis *smart contract* (*chaincode*). Konsensus pengurutan transaksi dikelola secara terdesentralisasi oleh klaster *ordering service* berbasis SmartBFT (Node 1 sampai 4) yang mendistribusikan blok ke bar validasi dan pencatatan *ledger* guna verifikasi kebijakan endorsement dan validasi konflik versi MVCC. Sistem menerapkan penyimpanan hibrida: data transaksi bernilai tinggi (nomor lot universal, relasi silsilah antar-lot, jejak peristiwa serah terima, status mutu, status penarikan, serta *hash* dokumen pendukung) disimpan secara permanen pada *on-chain ledger*, sedangkan dokumen berukuran besar (berkas laporan uji laboratorium, faktur komersial, foto komoditas, dan rekaman telemetri sensor IoT) disimpan pada penyimpanan *off-chain* terenkripsi (IPFS atau penyimpanan cloud privat). Data komersial sensitif seperti harga pemasok dilindungi secara bilateral menggunakan *Private Data Collections* via protokol Fabric Gossip. Seluruh interaksi diamankan oleh *Certificate Authority* (CA) dan *Membership Service Provider* (MSP) berbasis PKI X.509 dan kontrol akses berbasis peran (RBAC), dengan negosiasi aturan di mana penerbitan hasil uji mutu mutlak menjadi wewenang laboratorium dan serah terima logistik mewajibkan endorsement ganda dari pengirim dan penerima.

1.4 Tetapkan dua indikator keberhasilan pilot project yang dapat diukur. [2 poin | CPMK 1 | C4]

Jawaban:

Dua indikator keberhasilan target rancangan pilot project yang diusulkan ditetapkan sebagai berikut:

1. Durasi Pelacakan Silsilah Lot (Recall Traceability Time): Waktu penelusuran silsilah lot lengkap dari hulu ke hilir ditargetkan terpangkas dari dua sampai tiga hari menjadi di bawah 15 menit, diuji melalui simulasi pengujian penarikan produk (*mock recall*) berkala hingga seluruh rantai pasok terdampak teridentifikasi.

2. Tingkat Kelengkapan Pencatatan Data Lot (Data Completeness Rate): Ditargetkan minimal 95% dari total pergerakan lot komoditas selama fase uji coba tercatat secara valid dan *end-to-end* pada *ledger on-chain*, diverifikasi melalui audit rekonsiliasi data mingguan antara basis data ERP internal dengan transaksi blockchain.

Kasus 2 Insiden Wallet Organisasi

Wallet treasury sebuah organisasi blockchain kehilangan aset setelah seorang staf menyetujui transaksi yang tampil sebagai pembaruan kontrak. *Log* menunjukkan login dari perangkat staf yang sah, tetapi domain antarmuka berbeda satu karakter dari domain resmi. *Private key* disimpan pada *browser wallet*; tidak ada *multisignature*, *allowlist* alamat, maupun prosedur respons insiden. Organisasi meminta analisis akar masalah dan rencana pemulihan.

2.1 Susun urutan kejadian yang paling mungkin dan bedakan fakta, hipotesis, serta bukti yang masih perlu dikumpulkan. [4 poin | CPMK 4 | C4]

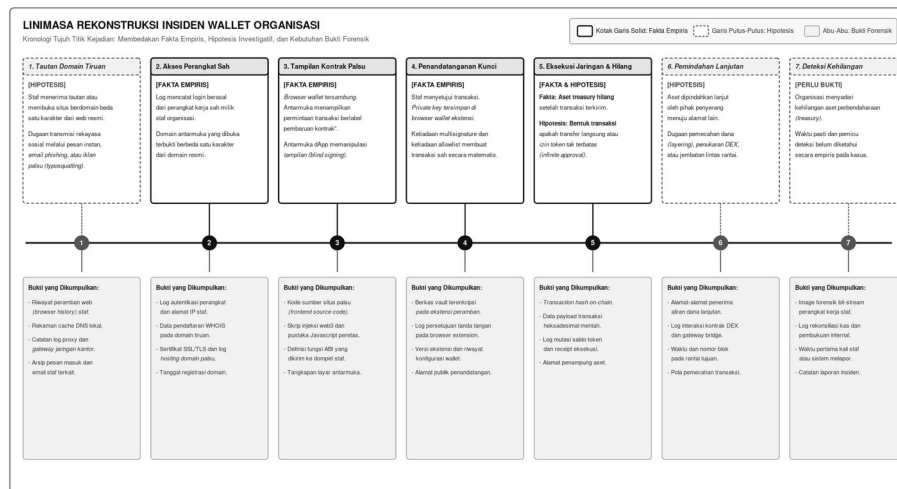
Jawaban:

Analisis pemilahan antara fakta kasus, hipotesis investigatif, dan bukti forensik digital yang perlu dihimpun disajikan pada Tabel 2.

Tabel 2. Pemilahan fakta, hipotesis, dan bukti forensik insiden

Fakta (Berdasarkan Teks Kasus)	Hipotesis Investigatif	Bukti Forensik yang Perlu Dikumpulkan
Login berasal dari perangkat staf sah; domain berbeda satu karakter.	Staf menjadi korban rekayasa sosial <i>phishing typosquatting</i> akibat kekeliruan navigasi atau tautan berbahaya.	Riwayat penjelajahan browser, DNS cache lokal, <i>log proxy</i> jaringan, dan data registrasi domain WHOIS.
Transaksi tampil sebagai 'pembaruan kontrak' pada antarmuka dApp.	Antarmuka palsu memanipulasi tampilan narasi transaksi untuk memicu persetujuan buta (<i>blind signing</i>).	Source code antarmuka web palsu, skrip injeksi web3, <i>payload</i> transaksi mentah, dan ABI <i>smart contract</i> .
<i>Private key</i> disimpan langsung pada <i>browser wallet</i> tanpa <i>multisignature</i> .	Kunci privat terekspos tanpa perlindungan otorisasi ganda atau segregasi wewenang operasional.	Berkas <i>vault browser wallet</i> terenkripsi, <i>log</i> ekstensi peramban, dan riwayat otorisasi izin dApp.
Staf menyetujui dan menandatangani transaksi menggunakan <i>private key</i> .	Muatan transaksi berisi instruksi transfer saldo langsung atau persetujuan <i>token</i> tak terbatas.	<i>Transaction hash on-chain</i> , data heksadesimal input transaksi, dan status pemindahan aset.
Aset treasury hilang; ketiadaan <i>allowlist</i> dan SOP respons insiden.	Ketiadaan batas transaksi memungkinkan penyerang menguras saldo treasury dalam sekali eksekusi.	Alamat penampung aset milik penyerang di blockchain dan salinan mutasi buku besar internal.

Rekonstruksi kronologis kejadian berdasarkan tahapan waktu divisualisasikan dalam bentuk linimasa kejadian pada Gambar 2.



Gambar 2. Linimasa kejadian insiden wallet organisasi

Penjelasan Gambar: Linimasa pada Gambar 2 memetakan tujuh titik kejadian secara kronologis dari kiri ke kanan. Garis solid merepresentasikan fakta empiris yang terkonfirmasi (login perangkat sah, narasi antarmuka palsu, persetujuan staf via *browser wallet*, dan hilangnya saldo treasury), sedangkan garis putus-putus merepresentasikan hipotesis investigatif (distribusi tautan jebakan, bentuk muatan transaksi transfer/approval, perpindahan lanjut oleh penyerang, dan waktu organisasi pertama kali menyadari insiden). Pada baris bawah, setiap tahapan dipadukan dengan inventarisasi bukti digital yang wajib diakuisisi oleh tim investigasi guna pembuktian komprehensif.

2.2 Jelaskan bagaimana tanda tangan digital tetap valid meskipun transaksi terjadi akibat rekayasa sosial. [3 poin | CPMK 3 | C4]

Jawaban:

Tanda tangan digital berbasis kriptografi kurva eliptik (ECDSA secp256k1) tetap valid secara teknis karena protokol blockchain hanya menguji keabsahan matematis dari pasangan kunci dan integritas pesan data, bukan menguji intensi atau konteks kebenaran manusiawi pembuat tanda tangan (kebutaan semantik atau semantic blindness).

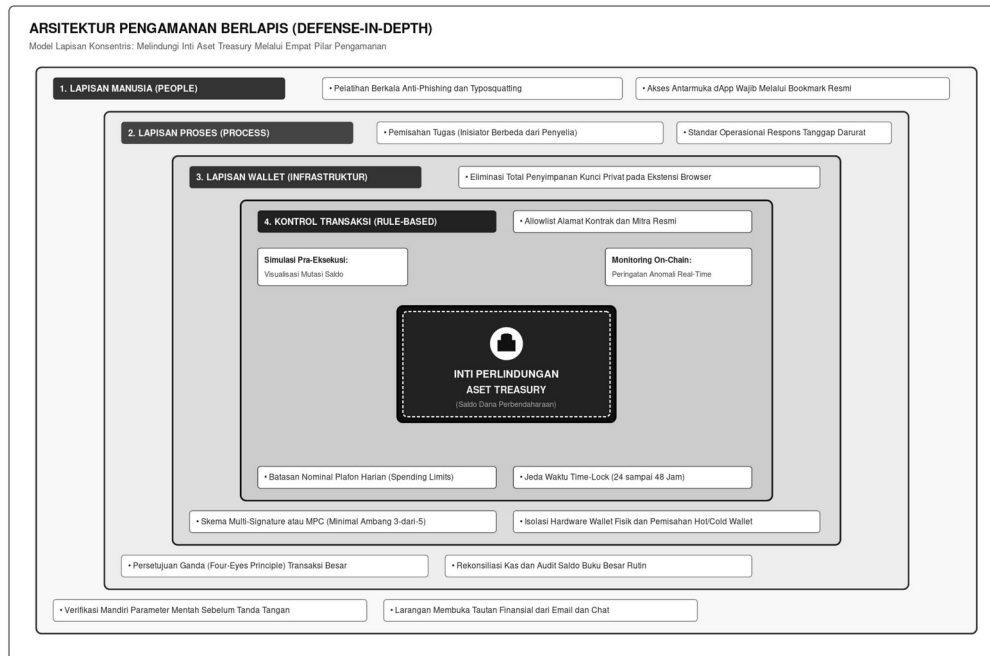
Secara operasional, verifikasi kriptografis membuktikan dua kondisi mutlak: pertama, transaksi ditandatangani oleh pemegang *private key* sah yang berpasangan secara matematis dengan *public key* pengirim; kedua, muatan biner *payload* transaksi tidak mengalami perubahan sedikit pun sejak penandatanganan dilakukan. Ketika staf terpedaya rekayasa sosial, staf secara sadar mengeksekusi instruksi penandatanganan menggunakan *private key* resmi yang tersimpan di dalam *browser wallet*.

Pada kasus ini berlangsung fenomena *blind signing*: antarmuka dApp palsu menampilkan teks manipulatif 'Pembaruan Kontrak', padahal *payload* heksadesimal mentah yang disodorkan adalah instruksi pemindahan saldo atau approval tak terbatas. Karena penandatanganan dilakukan menggunakan *private key* yang sah, validator jaringan memproses transaksi tersebut sebagai instruksi yang sepenuhnya legal, terlepas dari fakta bahwa persetujuan staf didasari oleh manipulasi informasi visual.

2.3 Rancang pengamanan berlapis yang mencakup manusia, proses, wallet, dan kontrol transaksi. [5 poin | CPMK 3 dan CPMK 4 | C6]

Jawaban:

Kerangka arsitektur pertahanan berlapis dirancang secara terpusat mengelilingi aset treasury sebagaimana diilustrasikan pada Gambar 3.



Gambar 3. Pengamanan berlapis aset treasury

Penjelasan Gambar: Gambar 3 mengilustrasikan strategi pertahanan berlapis konsentris yang membentengi aset treasury pada inti terdalam. Dari luar ke dalam, lapisan pertama adalah Manusia (pelatihan anti-*phishing* berkala, verifikasi domain secara mandiri, dan kewajiban bookmark dApp resmi). Lapisan kedua adalah Proses (pemisahan wewenang inisiator dan penyelia, persetujuan ganda dua orang untuk transaksi besar, SOP respons insiden darurat, dan rekonsiliasi kas harian). Lapisan ketiga adalah *Wallet* (migrasi ke *multisignature* minimal 3-dari-5 atau MPC, isolasi kunci fisik via *hardware wallet* berfitur *clear signing*, eliminasi *browser wallet*, serta pemisahan *hot wallet* dan *cold storage*). Lapisan keempat adalah Kontrol Transaksi (*allowlist* alamat mitra resmi, pembatasan plafon pengeluaran harian, *time-lock* 24 sampai 48 jam, simulasi pra-tanda tangan, serta sistem monitoring dan peringatan anomali real-time).

2.4 Tentukan tindakan pada 24 jam pertama dengan tetap menjaga integritas bukti digital. [3 poin | CPMK 4 | C5]

Jawaban:

Tindakan sistematis pada 24 jam pertama dengan memprioritaskan penjagaan integritas bukti digital dirancang dalam empat fase waktu:

1. Jam 0 sampai 2 (Isolasi Non-Destruktif dan Preservasi Bukti Volatil): Putuskan perangkat kerja staf dari jaringan fisik dan nirkabel seketika tanpa mematikan daya guna menjaga memori RAM. Lakukan akuisisi *memory dump* untuk mengamankan *session token* dan proses injeksi skrip, dilanjutkan pembuatan citra *bit-stream disk image* terverifikasi hash SHA-256.

2. Jam 2 sampai 6 (Containment dan Penyelamatan Cadangan Aset): Lakukan audit status *on-chain* dari perangkat bersih yang terisolasi. Segera cabut (revoke) seluruh izin *allowance token* yang terkompromi melalui *smart contract* darurat, lalu amankan sisa saldo kas ke *cold storage* atau *vault multisignature* baru yang aman.

3. Jam 6 sampai 12 (Tracing On-Chain dan Koordinasi Eksternal): Petakan pergerakan dana peretas di blockchain dan identifikasi alamat perantara. Kirimkan permohonan pembekuan aset darurat (*emergency freeze request*) yang memuat bukti *transaction hash* kepada entitas exchange terpusat (CEX) yang terdeteksi menerima aliran dana.

4. Jam 12 sampai 24 (Konsolidasi Forensik dan Pelaporan Hukum): Amankan *log proxy*, *log gateway*, dan catatan DNS server internal. Susun laporan kronologis insiden awal bagi manajemen dan unit kepolisian siber, serta terbitkan pernyataan publik yang terukur tanpa membocorkan rincian teknis yang dapat dieksploitasi pihak lain.

Kasus 3 Audit Smart Contract Vault

Sebuah *vault* menerima setoran *token* dan memungkinkan pengguna menarik saldo. Pengembang menuliskan alur penarikan secara sederhana: kontrak memeriksa saldo, mengirim *token* atau aset kepada pemanggil melalui *external call*, lalu mengurangi saldo pengguna. Kontrak juga menggunakan *oracle* harga tunggal dan fungsi admin untuk mengganti alamat *oracle* tanpa *time-lock*. Deployment direncanakan langsung ke *mainnet* tanpa pengujian *invariant*.

3.1 Identifikasi sekurang-kurangnya tiga kerentanan atau kelemahan desain beserta dampaknya. [4 poin | CPMK 3 dan CPMK 4 | C4]

Jawaban:

Berdasarkan evaluasi terhadap kode *smart contract vault*, diidentifikasi empat kerentanan desain kritis beserta dampaknya yang dirangkum pada Tabel 3.

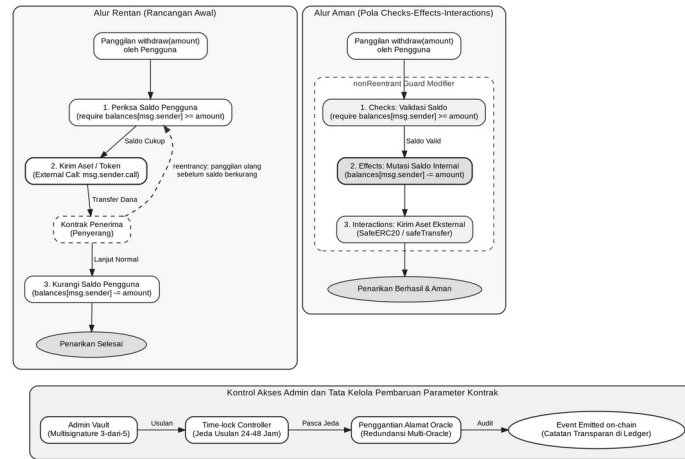
Tabel 3. Matriks identifikasi kerentanan *smart contract vault*

Kerentanan Desain	Akar Penyebab Teknis	Potensi Dampak Kerugian
Kerentanan <i>Reentrancy</i> pada Alur Penarikan	Panggilan eksternal (<i>external call</i>) mendahului pembaruan saldo internal pengguna (<i>balances[msg.sender]</i>).	Kritis; penyerang dapat mengeksekusi penarikan rekursif via <i>fallback function</i> hingga cadangan kas terkuras.
Ketergantungan <i>Oracle</i> Harga Tunggal	Kontrak hanya mengandalkan satu sumber <i>oracle</i> harga <i>spot</i> tanpa redundansi atau filter perata harga.	Tinggi; rentan manipulasi kilat melalui flash loan dalam satu blok transaksi, merusak kalkulasi nilai penarikan.
Ketiadaan <i>Time-Lock</i> pada Kontrol Admin	Fungsi pergantian alamat <i>oracle</i> dapat dieksekusi secara instan oleh akun pengendali tanpa jeda tunda.	Tinggi; jika <i>private key</i> admin bocor, penyerang dapat mengganti <i>oracle</i> ke kontrak jahat dan merampas aset pengguna.
Ketiadaan <i>Circuit Breaker</i> dan Uji <i>Invariant</i>	Rencana deployment langsung ke <i>mainnet</i> tanpa fungsi pause darurat dan tanpa pengujian matematis <i>invariant</i> .	Sedang-Tinggi; pengelola tidak memiliki mekanisme intervensi saat insiden berlangsung, menjamin kerugian permanen.

3.2 Usulkan perbaikan urutan logika penarikan dan kontrol akses admin. Jelaskan alasan setiap kontrol. [5 poin | CPMK 3 | C6]

Jawaban:

Perbandingan komparatif alur penarikan rentan lawan aman beserta arsitektur kontrol akses admin ditampilkan pada Gambar 4.



Gambar 4. Perbandingan alur penarikan rentan lawan aman dan kontrol administratif

Penjelasan Gambar: Gambar 4 membandingkan alur penarikan rentan lawan aman disertai kontrol administratif. Pada alur rentan, panggilan eksternal mendahului pengurangan saldo internal sehingga memicu celah *reentrancy*. Alur aman menerapkan pola *Checks-Effects-Interactions* (validasi saldo, mutasi saldo internal, lalu transfer aset) berbalut modifier *nonReentrant guard*. Panel bawah mengamankan kontrol admin melalui *multisignature*, *time-lock* 24 sampai 48 jam, dan pencatatan event *on-chain* sebelum pergantian *oracle* diberlakukan.

Rincian argumentasi dan alasan teknis perbaikan kontrol dirumuskan sebagai berikut:

- 1. Pola Checks-Effects-Interactions (CEI):** Urutan instruksi dibalik: validasi input (*require* saldo mencukupi), kurangi variabel saldo internal pemanggil pada penyimpanan kontrak, kemudian eksekusi transfer *token* ke alamat eksternal. Alasan: Mencegah eksploitasi *reentrancy* karena saldo pengguna telah terpotong sebelum transfer terjadi.
- 2. Proteksi Mutex Guard (*nonReentrant*):** Menambahkan modifier pengunci *nonReentrant* dari pustaka OpenZeppelin sebagai pertahanan lapis kedua. Alasan: Mengunci status fungsi penarikan agar tidak dapat dipanggil kembali selama instruksi eksternal sebelumnya belum rampung sepenuhnya.
- 3. Pembungkus Transfer Aman (*SafeERC20*):** Menggunakan fungsi *safeTransfer* untuk membungkus pengiriman *token* ERC-20. Alasan: Mengantisipasi *token* non-standar yang tidak mengembalikan nilai boolean *true* agar transaksi tidak gagal secara tersembunyi.
- 4. Pengendali Antrean Waktu (*Time-Lock Controller 24-48 Jam*):** Setiap instruksi penggantian alamat *oracle* wajib dimasukkan ke antrean publik dengan jeda tunda 24 sampai 48 jam disertai emisi event *on-chain*. Alasan: Memberikan jeda waktu bagi para penyeter modal untuk memeriksa perubahan parameter dan menarik aset secara aman.
- 5. Redundansi Multi-Oracle Terdesentralisasi:** Menggabungkan data *oracle* harga Chainlink terdesentralisasi dengan *oracle* TWAP DEX, dilengkapi batas keusangan data (*staleness check*) dan deviasi harga maksimum. Alasan: Meniadakan titik kegagalan tunggal dan menolak manipulasi harga instan berbasis flash loan.

3.3 Rancang strategi pengujian yang memuat unit test, fuzzing atau property-based test, serta invariant utama. [4 poin | CPMK 3 dan CPMK 4 | C6]

Jawaban:

Strategi pengujian komprehensif *smart contract* dan *invariant* kritis yang diverifikasi dirangkum pada Tabel 4.

Tabel 4. Matriks strategi pengujian dan verifikasi *invariant*

Tingkat / Jenis Pengujian	Sasaran dan Metode Pengujian	Invariant / Sifat Kritis yang Diverifikasi
Unit Testing (Deterministik)	Pengujian alur normal dan kasus batas (setoran, penarikan saldo nol, penarikan melampaui saldo, otorisasi fungsi admin).	Pengecekan kondisi saldo tepat, pembalikan transaksi (revert) saat saldo kurang, dan penolakan pemanggil non-admin.
Simulasi Serangan <i>Reentrancy</i>	Menyusun kontrak uji tiruan (<i>mock exploit contract</i>) yang mencoba memanggil fungsi <code>withdraw()</code> secara rekursif via <i>fallback</i> .	Pola CEI dan <i>nonReentrant guard</i> sukses menolak eksekusi rekursif kedua, mempertahankan integritas saldo <i>vault</i> .
Fuzzing & Property-Based Testing	Mengeksekusi ratusan ribu kombinasi urutan transaksi dan nominal acak ekstrem menggunakan Foundry atau Echidna.	Mendeteksi potensi kesalahan pembulatan aritmatika (rounding errors) serta celah <i>underflow</i> dan <i>overflow</i> numerik.
Formal Invariants Verification	Membuktikan kebenaran sifat matematis absolut kontrak di seluruh perubahan status transaksi.	Solvabilitas cadangan: $\text{TotalAsetFisik} \geq \text{TotalKewajiban}$; Non-negativitas: saldo akun tidak pernah bernilai minus.
Audit Statis & Uji Coba <i>Testnet</i>	Pemindaian kerentanan kode otomatis via analisis statis (Slither) dan uji coba operasional terintegrasi di <i>testnet</i> publik.	Bebas peringatan kelemahan logika; stabilitas interaksi kontrak dengan <i>token</i> standar dan non-standar selama simulasi.

3.4 Putuskan apakah deployment harus dilanjutkan atau ditunda dan nyatakan kriteria go atau no-go. [2 poin | CPMK 4 | C5]

Jawaban:

Keputusan Evaluasi: TUNDA (NO-GO) secara mutlak terhadap rencana deployment ke *mainnet* sampai seluruh kerentanan kritis diperbaiki dan diuji tuntas.

Empat Kriteria Go / No-Go Terukur yang Wajib Dipenuhi Sebelum Rilis:

1. Remediasi Tuntas Kerentanan Kritis: Celah *reentrancy*, ketergantungan *oracle* tunggal, dan fungsi admin instan telah diperbaiki sepenuhnya serta memperoleh surat verifikasi bersih dari auditor keamanan eksternal independen.

2. Kelulusan Uji Invariant Fuzzing: Kontrak berhasil melewati pengujian *fuzzing* minimal 100.000 iterasi transaksi acak tanpa satupun pelanggaran terhadap *invariant* solvabilitas aset *vault*.

3. Implementasi Kontrol Multi-Signature dan Time-Lock: Hak akses administratif telah dialihkan ke *smart contract multisignature* minimal 3-dari-5 dan *time-lock controller* 24 sampai 48 jam telah aktif terpasang pada jaringan.

4. Validasi Stabilitas Testnet Publik: Kontrak beroperasi tanpa kendala di *testnet* publik selama minimal dua minggu, dilanjutkan peluncuran bertahap (*canary launch*) dengan pembatasan plafon setoran (*deposit cap*) ketat pada fase awal.

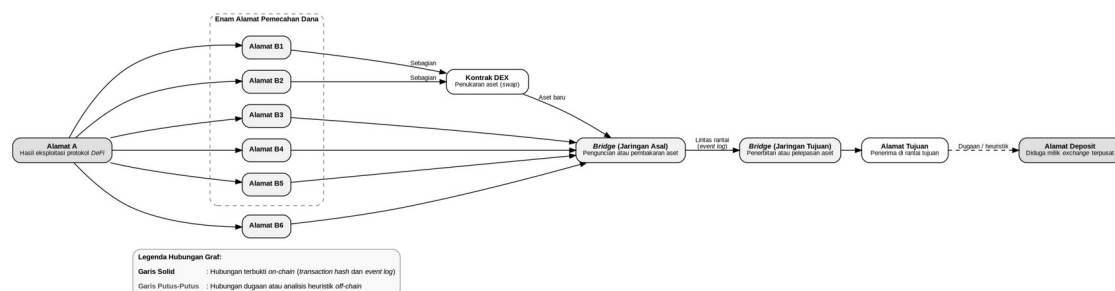
Kasus 4 Investigasi Aliran Dana Lintas Jaringan

Sebuah alamat A menerima aset hasil eksploitasi protokol DeFi. Dana kemudian dipecah ke enam alamat, sebagian ditukar melalui *decentralized exchange*, lalu dipindahkan melalui *bridge* ke jaringan lain. Salah satu alamat tujuan mengirim dana ke alamat deposit yang diduga milik exchange terpusat. Tim investigasi memiliki *transaction hash*, timestamp, alamat kontrak, dan *log event*, tetapi belum memiliki informasi identitas pemilik alamat.

4.1 Jelaskan metode rekonstruksi aliran dana dan artefak on-chain yang harus dikumpulkan. [4 poin | CPMK 4 | C4]

Jawaban:

Pemetaan aliran dana dari alamat awal hasil eksploitasi menuju entitas bursa direkonstruksi dalam graf transaksi pada Gambar 5.



Gambar 5. Graf rekonstruksi aliran dana lintas jaringan

Penjelasan Gambar: Graf pada Gambar 5 merekonstruksi aliran dana peretasan secara terstruktur dari kiri ke kanan. Dimulai dari Alamat A sebagai penampung awal hasil eksploitasi protokol DeFi, dana disebar ke enam alamat perantara (Alamat B1 sampai B6) untuk memecah jejak transaksi. Sebagian dana (diilustrasikan melalui Alamat B1 dan B2) dialirkan ke kontrak *router decentralized exchange* (DEX) guna menukar *token* hasil curian menjadi aset kripto lain, sementara alamat lainnya mengirimkan dana langsung ke gerbang kontrak *bridge* jaringan asal. Pada *bridge* asal, aset dikunci atau dibakar, memicu emisi *event log* lintas rantai yang menginstruksikan *bridge* jaringan tujuan menerbitkan aset pengganti kepada Alamat Tujuan. Dari Alamat Tujuan, dana dikirimkan ke Alamat Deposit. Hubungan garis solid menunjukkan transaksi yang terbukti mutlak via *transaction hash on-chain*, sedangkan garis putus-putus menunjukkan atribusi kepemilikan alamat deposit bursa terpusat yang didasarkan pada analisis heuristik *sweeping saldo*.

Metode Rekonstruksi dan Pengumpulan Artefak On-Chain:

1. Rekonstruksi Aliran Dana Berbasis Graf: Penyelidikan memanfaatkan pemodelan graf terarah (Directed Acyclic Graph) untuk memetakan alamat sebagai *node* dan transfer aset sebagai *edge*. Proses mencakup dekonvolusi pemecahan dana (*fan-out layering*), penguraian *log event* pertukaran *token* (Transfer, Swap, Sync) pada *router DEX*, serta pencocokan relasi stempel waktu dan *nonce* peristiwa *bridge* lintas jaringan.

2. Inventarisasi Artefak On-Chain Kritis: Artefak yang wajib dihimpun mencakup parameter transaksi (*transaction hash*, nomor blok, stempel waktu presisi UTC, *origin*), entitas alamat pengirim dan penerima, alamat *smart contract token* dan gateway *bridge*, data *log event* mentah beserta topik terindeks, rekaman *internal trace* eksekusi panggilan kontrak, resi status transaksi (*receipt*), serta pemakaian bahan bakar transaksi (*gas fee*).

4.2 Nilai kekuatan dan keterbatasan heuristik common-input, clustering waktu, dan hubungan alamat deposit. [4 poin | CPMK 4 | C5]

Jawaban:

Evaluasi perbandingan analitis mengenai kekuatan dan keterbatasan ketiga metode heuristik blockchain disajikan pada Tabel 5.

Tabel 5. Evaluasi kekuatan dan keterbatasan heuristik analisis blockchain

Metode Heuristik	Kekuatan Analisis Forensik	Keterbatasan Teknis
<i>Common-Input Ownership</i> (Catatan: Berasal dari Model UTXO)	Sangat andal pada arsitektur UTXO (Bitcoin); penggabungan beberapa input dalam satu transaksi membuktikan kepemilikan oleh satu entitas yang sama.	Tidak berlaku langsung pada model berbasis akun (Ethereum/EVM) karena setiap transaksi hanya memiliki satu pengirim (msg.sender). Analisis EVM beralih ke sumber <i>gas fee</i> awal bersama atau penandatanganan <i>multisignature</i> .
<i>Clustering</i> (<i>Temporal Analysis</i>)	Waktu Efektif mendeteksi otomatisasi bot, seperti distribusi saldo ke enam alamat dalam blok yang sama atau selisih detik yang sangat teratur.	Rentan kesalahan positif akibat kongesti jaringan global; mudah dikaburkan penyerang dengan menyetel jeda waktu acak (randomized delay).
Hubungan Alamat Deposit (<i>Deposit Address Clustering</i>)	Sangat kuat mengaitkan alamat <i>on-chain</i> dengan entitas bursa resmi via pola penyapuan saldo (<i>sweeping</i>) ke <i>hot wallet</i> utama exchange.	Hanya mengidentifikasi platform penyedia layanan bursa, bukan identitas manusia pemilik akun, karena pelaku kerap memakai akun sewaan (<i>mule account</i>).

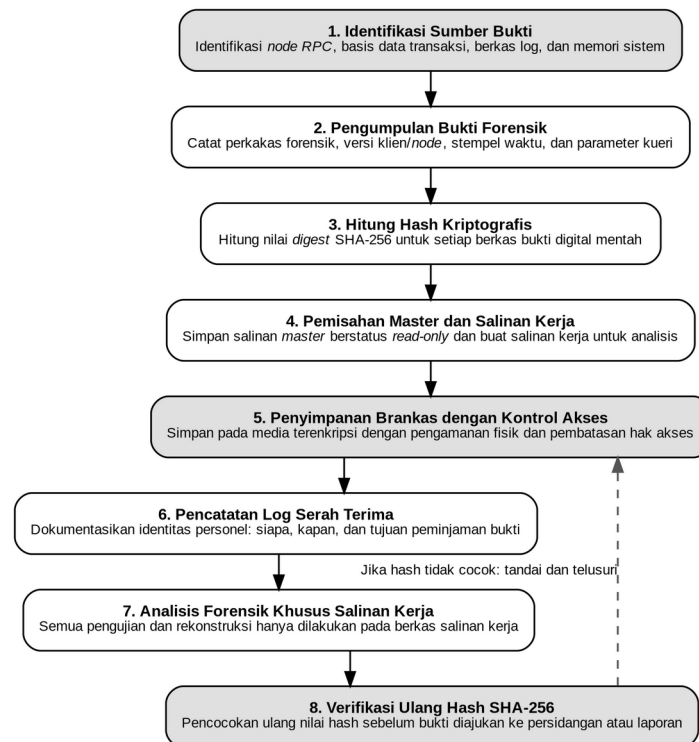
Uraian Analisis Heuristik:

Penerapan ketiga heuristik tersebut memerlukan pendekatan kontekstual sesuai model arsitektur buku besar. Heuristik *common-input ownership* memberikan dasar pembuktian kepemilikan dompet tunggal yang sangat kuat pada ekosistem UTXO seperti Bitcoin melalui analisis masukan bersama, namun pada ekosistem EVM analisis harus mengalihkan fokus pada transaksi pembiayaan *gas fee* awal atau kesamaan alamat penandatanganan kontrak multi-pemilik. Sementara itu, analisis temporal *clustering* mampu mengungkap keterlibatan skrip otomatisasi bot penyerang dalam mengeksekusi pemecahan dana secara serentak, meskipun analisis harus mewaspadaai upaya penyamaran berupa penyisipan jeda waktu acak. Pada tahap akhir, *deposit address clustering* menjadi kunci krusial untuk menghubungkan transaksi pseudonim blockchain dengan entitas penyedia layanan aset virtual resmi di dunia nyata melalui pelacakan *sweeping* saldo.

4.3 Susun chain of custody untuk menjaga bukti hasil ekstraksi blockchain dan data pendukung off-chain. [4 poin | CPMK 4 | C6]

Jawaban:

Bagan alir prosedur preservasi bukti digital forensik dirumuskan dalam rantai penjagaan (*chain of custody*) pada Gambar 6.



Gambar 6. Alur chain of custody preservasi bukti digital blockchain

Penjelasan Gambar: Gambar 6 menggambarkan bagan alir terstruktur *chain of custody* dalam delapan tahapan berurutan untuk menjamin integritas bukti forensik digital di mata hukum. Dimulai dari identifikasi sumber bukti digital (*node* RPC, basis data *log*, memori sistem), dilanjutkan pengumpulan bukti dengan dokumentasi perkakas, versi klien, stempel waktu, dan parameter kueri. Tahap ketiga adalah perhitungan nilai *hash* kriptografis SHA-256 seketika untuk setiap berkas mentah. Tahap keempat memisahkan salinan master berstatus *read-only* dari salinan kerja (*working copy*). Tahap kelima mengamankan penyimpanan bukti pada media terenkripsi di dalam brankas fisik dengan pembatasan hak akses ketat. Tahap keenam mencatat setiap riwayat peminjaman pada *log* serah terima bertanda tangan (siapa, kapan, dan tujuan peminjaman). Tahap ketujuh memastikan seluruh analisis forensik hanya dijalankan pada salinan kerja. Tahap kedelapan melakukan verifikasi ulang nilai *hash* SHA-256 sebelum bukti diajukan ke laporan investigasi atau persidangan; apabila *hash* tidak cocok, sistem memberi peringatan untuk menandai dan menelusuri anomali perubahan data.

4.4 Tuliskan kesimpulan investigatif yang membedakan atribusi alamat, atribusi layanan, dan atribusi individu. [3 poin | CPMK 4 | C5]

Jawaban:

Klasifikasi tingkatan atribusi investigasi beserta dasar pembuktian dan status kesimpulannya dirangkum pada Tabel 6.

Tabel 6. Tingkatan atribusi investigasi *on-chain* dan *off-chain*

Tingkat Atribusi	Dasar Bukti Pendukung	Tingkat Keyakinan	Status Kesimpulan
Atribusi Alamat (Address Attribution)	Catatan <i>transaction hash on-chain</i> , rekaman blok, <i>log event token</i> transfer, dan mutasi saldo.	Pasti (Deterministik)	Terbukti secara matematis dan permanen pada <i>ledger</i> publik bahwa alamat penampung menerima dana eksploitasi.
Atribusi Layanan (Service Attribution)	Interaksi dengan <i>smart contract</i> DEX, gateway <i>bridge</i> , serta transaksi <i>sweeping</i> saldo menuju klaster <i>hot wallet</i> bursa.	Tinggi (Analisis Perilaku)	Terbukti kuat bahwa alamat tujuan akhir berfungsi sebagai alamat deposit khusus milik entitas exchange terpusat.
Atribusi Individu (Individual Attribution)	Data pendaftaran akun bursa <i>off-chain</i> , rekaman identitas KYC, <i>log</i> alamat IP login, dan rekening penarikan fiat.	Belum Terbukti (Perlu Bukti Hukum)	Masih berupa hipotesis investigatif; identitas pelaku fisik mutlak memerlukan perintah pengadilan (<i>subpoena</i>) kepada exchange.

Uraian Kesimpulan Investigatif:

Investigasi membuktikan secara pasti pada tingkat atribusi alamat bahwa dana hasil eksploitasi mengalir dari Alamat A melalui enam alamat perantara, sebagian dikonversi di DEX, dan diseberangkan melalui *bridge* menuju alamat tujuan. Pada tingkat atribusi layanan, jejak transaksi membuktikan dengan tingkat keyakinan tinggi bahwa alamat penerima akhir terafiliasi dengan entitas exchange terpusat tertentu berdasarkan karakteristik penyapuan saldo ke klaster *hot wallet* bursa. Namun, pada tingkat atribusi individu, identitas manusia di balik pengendali alamat belum dapat disimpulkan karena transaksi blockchain bersifat pseudonim. Penetapan tersangka secara hukum memerlukan langkah investigasi *off-chain* melalui penerbitan surat perintah pengadilan (*subpoena*) kepada bursa terkait guna membuka catatan identitas KYC, *log* alamat IP akses, dan rekening penarikan fiat yang terhubung.